

TERASWAP

Comprehensive Technical Analysis

v2 — with Architect Corrections

Architecture, Security, Operations & Maturity Report

Classification: CONFIDENTIAL

Date: 23 April 2026 (updated from 22 April 2026 v1)

Prepared for: TeraHash (Founder / Architect)

Role: Lead Software Architect, Security Reviewer, Technical Product Analyst

Based on full source code review of the TeraSwap repository: 130+ source files, 11 DEX adapters, 20+ API routes, 2 smart contracts, 401 tests (all passing).

This v2 incorporates all factual corrections, missing coverage additions, severity upgrades, and remediation plan from the Architect's response dated 23 April 2026.

1. Executive Technical Summary

1.1 What TeraSwap Is

TeraSwap is a DEX meta-aggregator for Ethereum mainnet (chainId 1). It queries 11 independent decentralised exchange aggregator APIs in parallel (1inch, 0x, Odos, Velora/ParaSwap, KyberSwap, CoW Protocol, Uniswap V3, OpenOcean, SushiSwap, Balancer, Curve), compares their quoted outputs after gas costs, and routes the user's swap through the source offering the best net output. Optionally, a split-routing engine distributes a single swap across multiple sources to maximise output when no single source dominates.

The platform collects a 0.1% fee via a bespoke FeeCollector smart contract that interposes between the user's token approval and the downstream DEX router. An autonomous order engine supports limit orders, stop-loss/take-profit, and dollar-cost averaging (DCA) via a separate OrderExecutor contract with Chainlink oracle triggers and an external keeper network.

The frontend is a Next.js 16 application deployed on Vercel (Hobby tier, with Deployment Protection enabled post-breach), with Capacitor wrappers for iOS and Android. State persistence uses **Upstash Redis via @upstash/redis 1.37.0** (REST API) for monitoring/rate-limiting and Supabase (PostgreSQL) for analytics, order storage, and security events.

1.2 How It Works (End-to-End Flow)

The core swap flow proceeds through eight stages: **(1)** the user selects tokens and amount; **(2)** the frontend calls `/api/quote`, which fans out to all 11 adapters in parallel with 5-second timeouts and circuit-breaker filtering; **(3)** quotes are normalised, gas-adjusted, outlier-filtered (3x median threshold), and sorted; **(4)** the user reviews the best quote via QuoteBreakdown and optionally a split-route visualisation; **(5)** the Chainlink pre-swap oracle (`useChainlinkPrice`) compares the execution price against on-chain oracle feeds — blocking at $\geq 3\%$ deviation and warning at $\geq 2\%$; **(6)** `/api/swap` fetches execution calldata from the chosen source, validates the calldata recipient against the user's wallet address, checks known swap selectors, and performs a DefiLlama server-side price guard for swaps above \$10k; **(7)** the frontend runs an `eth_call` simulation, displays a TransactionPreview modal with decoded calldata ('clear signing'), and waits for explicit user confirmation; **(8)** the transaction is submitted on-chain, a post-execution validator checks actual vs expected output via Transfer event logs, and any critical shortfall auto-disables the responsible source.

1.3 Maturity Level

TeraSwap is a **late-beta product**. After 8 complete sprints with auditor-verified prompt packets and **401 passing tests**, it has accumulated substantial security infrastructure: constant-time bearer auth, quorum consensus anomaly detection, TLS/DNS fingerprint monitoring, a 4-component monitoring stack with Telegram/Discord/Email alerting, a P0 kill-switch with admin friction, circuit-breaker collapse detection, a Sybil detector, and a **Chainlink pre-swap oracle with 29 token feeds**. The architecture is

well-documented (5 ADRs, 5 incident reports, 8+ sprint packets, operational hygiene review).

However, the product operates on Vercel Hobby tier (no SLA, though Deployment Protection is now active), has no frontend or hook-level tests (only server-side lib tests), split-swap execution is non-atomic, and the order engine relies on an external keeper network with no fallback. The system is ready for controlled beta with technically sophisticated users, but requires hardening before scaling.

1.4 Key Strengths

- **Defence-in-depth with 8 independent validation layers:** input validation, circuit breaker, Chainlink pre-swap oracle, quorum consensus, calldata recipient verification, known swap selector allowlist, server-side price guard, and post-execution balance check.
- Constant-time SHA-256 bearer token authentication across all admin/monitoring endpoints, preventing timing side-channel attacks.
- Clear signing UX via TransactionPreview that decodes calldata to show recipient, amounts, deadline, and selector validation status before user signs.
- Mature incident response culture: 5 documented incidents with root cause analysis, remediation commits, and auditor verdicts. Battle-tested secret rotation runbook.
- P0 alert classification with prefix-matching, centralised in a shared module after C-01 divergence fix.
- Comprehensive monitoring: Cloudflare Worker cron (60s, independent of Vercel), GitHub Actions watchdog (5min, fixed with redirect handling), TLS/DNS baseline validation, on-chain event scanning.
- **Post-breach hardening (April 2026):** GitHub App scoped to single repo, Deployment Protection enabled, all PATs deleted, branch protection active, env vars marked Sensitive.

1.5 Key Weaknesses

- Zero frontend/hook test coverage: SwapBox, useSwap, useApproval, TransactionPreview, TokenSelector — all untested.
- Split-swap non-atomicity: multi-leg swaps execute sequentially; partial failure and per-leg MEV exposure.
- KV rate limiter fail-open: if Upstash Redis is unavailable, rate limiting is silently bypassed.
- Vercel Hobby tier: no SLA, 10s function timeout for most routes (though Deployment Protection now active).
- In-memory circuit breaker per adapter resets on cold start; takes ~3 failures (~90s) to rebuild protection.
- Systemic circuit breaker (P46) is alert-only, does not automatically halt swap routing when majority of sources fail.

2. System Architecture

2.1 Technology Stack

Layer	Technology	Version / Detail
Frontend Framework	Next.js (App Router)	16.2.3
UI Library	React	18.3.0
Styling	Tailwind CSS	3.4.0
Wallet Integration	RainbowKit + wagmi + viem	2.1.0 / 2.19.5 / 2.47.4
State Management	Zustand + React Query	4.5.0 / 5.50.1
Animations	Framer Motion	12.36.0
Hosting / Deploy	Vercel (Hobby + Deployment Protection)	Next.js runtime
KV Store	Upstash Redis (REST)	@upstash/redis 1.37.0
Database	Supabase (PostgreSQL)	@supabase/supabase-js 2.99.1
Error Monitoring	Sentry	@sentry/nextjs 10.43.0
Mobile	Capacitor (iOS + Android)	8.2.0
Smart Contracts	Solidity (Foundry/Forge)	FeeCollector + OrderExecutor
Monitoring Scheduler	Cloudflare Worker (independent of Vercel)	Cron trigger */60
External Watchdog	GitHub Actions (redirect-aware)	5-minute polling
Chainlink Oracle Registry	AggregatorV3 on-chain feeds	29 tokens
Testing	Vitest	4.1.4 (401 tests passing)
Language	TypeScript (strict)	5.5.2

2.2 Module Architecture

The codebase is organised into 7 primary layers:

- **src/app/api/** — 20+ Next.js API routes (server-side, serverless functions). The system's external boundary. Includes a server-side analytics API (/api/analytics) that queries Supabase directly.
- **src/lib/adapters/** — 11 DEX adapter modules, each implementing a normalised interface for fetching quotes and swap calldata.
- **src/lib/** — ~50 modules covering security (auth, rate limiting, circuit breakers, calldata validation, Chainlink oracle), state (KV via @upstash/redis, Supabase), monitoring, and business logic.
- **src/components/** — ~40 React components: swap UI, order panels, analytics dashboard, security UX (TransactionPreview, Permit2EducationModal, WalletSessionGuard).

- **src/hooks/** — 16 custom hooks including useChainlinkPrice (pre-swap oracle guard), useSwap, useApproval.
- **contracts/** — Solidity: TeraSwapFeeCollector (fee interception + router whitelist with 48h timelock) and TeraSwapOrderExecutor (autonomous order execution).
- **workers/** — Cloudflare Worker for monitoring cron trigger. Operates independently of Vercel — continues detecting failures even if Vercel is compromised.

2.3 Critical Dependencies & Integration Points

Dependency	Purpose	Failure Mode
Upstash Redis (REST)	Rate limiting, monitoring state, circuit breaker, heartbeat, grace periods	Fail-open for rate limiter; P0 alert for state writes; tick skips
Supabase (PostgreSQL)	Analytics, orders, security events, swap/quote logging	Graceful degradation (fire-and-forget); order creation fails
Chainlink Oracles (29 feeds)	Pre-swap price deviation detection, order triggers	Stale = oracle unavailable; blocks high-value swaps; warns user
DefiLlama API	Server-side price guard for high-value swaps	Fails-open <\$10k; blocks >\$10k if unavailable (3s timeout)
11 DEX APIs	Quote/swap data fetching	Circuit breaker per source; quorum consensus detects manipulation
Vercel (Hobby + Protection)	Hosting, serverless functions, edge routing	No SLA; 10s timeout; cold starts lose in-memory state
Cloudflare Worker	60s monitoring cron (independent of Vercel)	GitHub Actions watchdog detects staleness at 5-min intervals
Telegram Bot API	Interactive alerts + admin commands	Silent fallback if token/chat missing

2.4 Data Flow: Quote-to-Swap

1. User Input — SwapBox validates token addresses, amounts, balance. Debounced (300ms).

2. /api/quote — Rate-limited by IP via Upstash Redis. Fans out to 11 adapters via Promise.allSettled (5s timeout each). Circuit breaker filters open sources. Outliers >3x median removed. Gas-adjusted sort. Returns MetaQuoteResult with crossQuoteDeviation warning.

3. Chainlink Pre-Swap Oracle — useChainlinkPrice reads AggregatorV3 feeds on-chain via wagmi. Compares execution price against oracle price. Warn at >=2% deviation. Hard block at >=3% deviation. For tokens without a feed: explicit 'No Chainlink oracle available' warning and block above configurable USD threshold (\$5k warn, \$10k block).

4. Frontend Analysis — useSplitRoute evaluates multi-leg opportunity (>=10 bps improvement). QuoteBreakdown displays source comparison.

5. /api/swap — Rate-limited. Fetches execution calldata. Server-side defences: (a) known swap selector validation [SC-04]; (b) recipient-in-calldata verification [R1]; (c) DefiLlama price guard [INT-01] blocks >\$10k if oracle unavailable, warns 2-3%, blocks >3%.

6. Pre-Execution — eth_call simulation catches reverts, insufficient balance, STF errors, slippage failures. TransactionPreview decodes calldata: recipient badge, amounts, deadline, selector status. User must explicitly confirm.

7. On-Chain Execution — sendTransaction (standard) or EIP-712 sign + solver submission (CoW). Fallback receipt polling (3s interval, 2min timeout).

8. Post-Execution — /api/monitor/validate-execution checks Transfer event logs: actual vs expected. <=2% shortfall = warning; >2% = critical = P0 alert + auto-disable source. KV audit trail (7-day TTL).

2.5 Trust Boundaries

- **Trusted:** On-chain contracts (Uniswap V3, Curve — immutable), user wallet (signature authority), Chainlink oracles (staleness checked, 29 feeds).
- **Semi-trusted:** DEX aggregator APIs — verified by quorum consensus, calldata recipient validation, Chainlink oracle deviation, and post-execution balance checks.
- **Untrusted:** User input (validated server-side), external HTTP responses (timeout + error handling), browser environment (WalletSessionGuard, Permit2 education).

3. Deep Technical Walkthrough

3.1 Data Entry: Adapter Layer

Each DEX adapter implements a DEXAdapter interface with `fetchQuote()` and `fetchSwapData()` methods returning a `NormalizedQuote`. The 11 adapters fall into 3 categories:

- **API-based (7):** 1inch, 0x, Odos, Velora/ParaSwap, KyberSwap, OpenOcean, SushiSwap. HTTP calls to external APIs with server-only API keys.
- **On-chain (2):** Uniswap V3 (RPC `eth_call` to `QuoterV2`), Curve (RPC to `CurveRouterNG`). No external API dependency.
- **Intent-based (1):** CoW Protocol. Returns order parameters for EIP-712 signing, not transaction calldata. Excluded from split routing.
- **Hybrid (1):** Balancer. SOR API for routing + on-chain vault execution.

Shared utilities: `clampSlippage()` enforces 0.01-15% [L-01]; `withTimeout()` wraps every call in 5s Promise race; `toWeth()` converts native ETH to WETH; `deductFee()` uses integer BPS arithmetic (0.1% = 10 BPS).

3.1.1 Uniswap V3 Fee Tier Auto-Detection

Queries all 4 fee tiers (1, 5, 30, 100 bps) in parallel via `eth_call` to `QuoterV2`. Highest `amountOut` wins; on tie, lowest `gasEstimate` wins. Cached 45 min per pair (in-memory). Fully on-chain, no API dependency.

3.1.2 CoW Protocol Special Path

Intent-based: off-chain signed orders submitted to solver network for batch auction settlement (30s windows). Returns `cowOrderParams`, frontend switches to EIP-712 signing flow. Excluded from split routing.

3.2 Processing: Meta-Quote Orchestration

`fetchMetaQuote()` fans out to all non-disabled, circuit-breaker-closed sources via `Promise.allSettled()`. Outlier filter removes quotes >3x median. `crossQuoteDeviation` warns at >5% deviation from median. Global rate limiter (30 req/min) prevents cascading failures. `DISABLED_SOURCES` map permanently disables sources pending review (e.g., CoW Protocol post-2026-04-14 DNS hijack).

3.3 Validation Stack (8 Layers)

Architect Note: v2 correction: the Chainlink pre-swap oracle is now documented as Layer 3. Total layers updated from 7 to 8.

Layer 1: Input Validation

Regex-based address/txhash/amount validation. `safeCompare()` implements constant-time SHA-256 + `timingSafeEqual()` for bearer tokens [API-CRITICAL-01].

Layer 2: Circuit Breaker (Per-Adapter)

In-memory state machine: CLOSED -> OPEN (3 failures) -> HALF_OPEN (60s, 1 test) -> CLOSED. Resets on cold start.

Layer 3: Chainlink Pre-Swap Oracle

Implemented in `useChainlinkPrice.ts` and `chainlink.ts`. Reads `AggregatorV3 latestRoundData()` on-chain via wagmi hooks for **29 token feeds** (expanded from 24 on 22 April 2026, commit `de9e097`: added PAXG/USD, stETH/USD, FRAX/USD, LUSD/USD, GRT/USD). Compares execution price against oracle price with BigInt-safe arithmetic. Staleness check: rejects feeds older than 1 hour.

Deviation thresholds: none (<2%), warn (>=2%), danger (>=3%). At danger level, the swap button is **hard-blocked** — the user cannot override. For tokens without a Chainlink feed, the UI shows 'No Chainlink oracle available' and blocks swaps above a configurable USD threshold (\$5k warn, \$10k block). This is arguably the strongest single price protection feature in the system.

Layer 4: Quorum Consensus

Every 5th tick (~5 min): 2 reference pairs (1 ETH->USDC at 5%, 10k USDC->USDT at 2%). IQR pre-filter. BigInt-safe deviation. Sources deviating on both pairs disabled. >=3 correlated = P0 kill-switch. Minimum 5 active sources required.

Layer 5: Calldata Recipient Validation [R1]

19 known selectors across 6 groups. Extracts recipient from calldata. FAIL-CLOSED: unknown selectors blocked [API-M-02]. Valid recipients: user wallet OR FeeCollector address.

Layer 6: Known Swap Selector Allowlist [SC-04]

19 whitelisted DEX selectors. Used client-side and server-side (defence-in-depth).

Layer 7: Server-Side Price Guard [INT-01]

DefiLlama secondary oracle. Blocks >\$10k if unavailable (3s timeout). Warns 2-3%, blocks >=3%. Fails-open <\$10k. Consecutive-block tracking prevents abuse.

Layer 8: Post-Execution Balance Check [P45]

Transfer event log extraction + `balanceOf` fallback. Shortfall: ok (>=0), warning (0-2%), critical (>2% -> P0 + auto-disable). KV audit trail (7-day TTL).

3.4 Persistence & State

State is distributed across 4 backends:

- **Upstash Redis (@upstash/redis REST):** Monitoring state, rate limiter counters (sliding window sorted sets), alert dedup, on-chain scan cursor. Centralised client at `src/lib/kv.ts`.
- **Supabase (PostgreSQL):** Swap logs, quote logs, security events, wallet activity, orders, execution history. **Server-side analytics API (/api/analytics)** queries swaps table directly — this is the authoritative source of truth for the analytics dashboard.
- **localStorage:** Legacy client-side analytics (display-only, not authoritative), source preferences, Permit2 education state, session ID, swap history.
- **In-memory:** Per-adapter circuit breaker state, source health metrics (500-ping buffer), outbound rate limiter, fee tier cache.

3.5 Error Handling & Fallback

Critical paths fail-closed, analytics paths fail-open:

- **Adapter failures:** Circuit breaker opens; state machine transitions; quorum runs independently.
- **KV failures:** Rate limiter fails-open; state writes emit P0; tick retries next cycle.
- **Supabase failures:** Fire-and-forget (`Promise.resolve().catch()`); never blocks swaps.
- **Chainlink failures:** Stale feed = oracle unavailable. Blocks at danger threshold for covered tokens; warns/blocks by USD threshold for uncovered tokens.
- **RPC failures:** Post-execution returns 'unknown' (non-blocking). Receipt polling 2-min timeout.
- **Alert failures:** Each channel independent via `Promise.allSettled()`.

4. Security Review

Findings organised by severity. Each includes technical explanation, impact, risk, area, and recommendation. Architect response status shown in brackets.

Architect Note: v2 updates: M-01 upgraded to HIGH (per Architect assessment). L-03 upgraded to MEDIUM. L-02 downgraded (server-side analytics is now authoritative). All findings accepted by Architect with remediation planned.

4.1 Critical Findings

No unresolved critical findings. Previous criticals (C-01: P0 detection divergence) resolved with shared p0-reasons.ts module. The Vercel breach (INC-2026-04-19-001) has been fully remediated: secrets rotated, GitHub App scoped to single repo, Deployment Protection enabled, all PATs deleted, branch protection active, watchdog fixed (commit ec2c2bc).

4.2 High Findings

[High] H-01: KV Rate Limiter Fail-Open Design [ACCEPTED]

Explanation: kv-rate-limiter.ts returns { allowed: true } when Upstash Redis is unavailable. All rate limiting (quote: 30/min, swap: 20/min, RPC: 60/min) is silently bypassed during KV outage.

Impact: Attacker monitoring for KV downtime could flood all endpoints. /api/rpc becomes an open proxy.

Real Risk: MEDIUM-HIGH. INC-2026-04-14-002 confirms 13-day silent misconfiguration is a real-world precedent.

Area: [src/lib/kv-rate-limiter.ts](#)

Recommendation: Implement in-memory fallback rate limiter at 50% of normal limits when KV unavailable.

Architect Response: ACCEPTED. Remediation planned.

[High] H-02: Split Swap Non-Atomicity and MEV Exposure [ACCEPTED]

Explanation: useSplitSwap.ts executes multi-leg swaps sequentially. Each leg is independently sandwichable.

Impact: Partial execution + per-leg MEV exposure. Improvement threshold (10 bps) may not justify risk.

Real Risk: MEDIUM. Optional and opt-in, but users may not understand atomicity implications.

Area: [src/hooks/useSplitSwap.ts](#), [src/lib/split-router.ts](#)

Recommendation: Add explicit MEV risk warning. Raise improvement threshold to 50+ bps. Multicall atomic router post-launch.

Architect Response: ACCEPTED. Remediation planned.

[High] H-03: Systemic Circuit Breaker Is Alert-Only [ACCEPTED]

Explanation: Detects systemic collapse (≥ 6 disabled or ≥ 4 in 10-min cascade) but only emits P0 alert. Does not pause swap routing.

Impact: During coordinated attack, remaining (possibly compromised) sources continue serving users. With < 5 sources quorum is skipped: systemic collapse + quorum skip = no manipulation detection.

Real Risk: MEDIUM. The gap between systemic collapse and quorum skip is the key architectural risk.

Area: [src/lib/circuit-breaker.ts](#), [src/lib/monitoring-loop.ts](#)

Recommendation: Set global KV maintenance flag when tripped. `/api/quote` and `/api/swap` return HTTP 503. Manual clearance required.

Architect Response: ACCEPTED. Remediation planned.

[High] H-04: FeeCollector Forwards Arbitrary Calldata Without Output Validation [ACCEPTED]

Explanation: Contract pulls tokens, deducts fee, forwards calldata to whitelisted router. Does not validate output. Routers are upgradeable proxies (1inch, 0x).

Impact: Compromised router upgrade = loss of funds. Post-execution validation is async and can only detect.

Real Risk: MEDIUM. Router whitelist + 48h timelock mitigates but does not eliminate. Highest-priority SC finding.

Area: [contracts/TeraSwapFeeCollector.sol](#)

Recommendation: Add `minimumOutput` parameter to `swapTokenWithFee()`. Validate `tokenOut` balance after execution. Revert if insufficient.

Architect Response: ACCEPTED. Remediation planned.

[High] H-05: No Frontend or Hook Test Coverage [ACCEPTED]

Explanation: Zero automated tests for any React component or custom hook. `SwapBox`, `TransactionPreview`, `Permit2EducationModal`, `useSwap`, `useApproval`, `useQuote` — all untested. 401 tests all server-side.

Impact: Regressions in swap flow, approval logic, calldata display, or price guard enforcement ship silently. A bug in `TransactionPreview` that fails to display a mismatched recipient removes a critical security layer.

Real Risk: HIGH. The frontend is the user's last line of defence before signing. Untested security UX is a liability.

Area: [src/components/](#), [src/hooks/](#)

Recommendation: Prioritise: (1) `useSwap` fee validation; (2) `TransactionPreview` decoding; (3) `SwapBox` Chainlink guard; (4) `Permit2EducationModal` trigger.

Architect Response: ACCEPTED. Remediation planned.

Architect Note: v2: Upgraded from MEDIUM to HIGH per Architect's severity assessment (section 4.1 of response). The Architect confirmed: 'The frontend is the user's last line of defence before signing a transaction.'

4.3 Medium Findings

[Medium] M-01: In-Memory Adapter Circuit Breaker Loses State on Cold Start

[ACCEPTED]

Explanation: Per-adapter circuit breaker uses in-memory Map. Resets on cold start. Takes ~90s to re-open.

Impact: 90-second window where requests are sent to previously-failing sources.

Real Risk: LOW-MEDIUM. KV source state machine provides secondary protection but layers are not synchronised.

Area: [src/lib/adapters/circuit-breaker.ts](#)

Recommendation: On init, check KV source state. Pre-set to OPEN if disabled/degraded in KV.

Architect Response: ACCEPTED. Remediation planned.

[Medium] M-02: Supabase Service-Role Key Grants Full Write Access [ACCEPTED]

Explanation: Service-role key bypasses RLS for all server-side operations. Can read/write/delete any row.

Impact: Key compromise = full database access. Now marked Sensitive in Vercel post-breach.

Real Risk: MEDIUM. Server-only, but INC-2026-04-19-001 showed env exposure is possible.

Area: [src/lib/supabase.ts](#)

Recommendation: Dedicated INSERT-only role for logging tables. Service-role only for order operations.

Architect Response: ACCEPTED. Remediation planned.

[Medium] M-03: Grace Period Alert Suppression Inconsistent Across Channels

[ACCEPTED]

Explanation: Grace alerts sent to Telegram only ([GRACE] tag). Email/Discord receive full alerts.

Impact: Alert fatigue on non-Telegram channels during planned maintenance.

Real Risk: LOW. Functional but inconsistent.

Area: [src/lib/alert-wrapper.ts](#)

Recommendation: Apply [GRACE] tag to all channels. Or suppress non-P0 entirely with summary at grace end.

Architect Response: ACCEPTED. Remediation planned.

[Medium] M-04: On-Chain Monitor 5-Minute Cadence for Critical Events [ACCEPTED]

Explanation: Scans every 5th tick (~5 min). Critical events (Paused, OwnershipTransferred) detected with delay.

Impact: Malicious admin actions undetected for minutes. Paused/Unpaused bypass 48h timelock.

Real Risk: LOW-MEDIUM. Timelock provides larger window for most events but not Pause.

Area: [src/lib/on-chain-monitor.ts](#)

Recommendation: Run every tick (60s). Consider WebSocket for critical events.

Architect Response: ACCEPTED. Remediation planned.

[Medium] M-05: Telegram Inline Callback Buttons Not User-Validated [ACCEPTED]

Explanation: Callback queries (activate, keep, escalate, ack) do not verify the clicker is in TELEGRAM_ADMIN_IDS. Any group member can click action buttons — direct source control bypass.

Impact: Non-admin users could activate/disable sources. If group is shared for monitoring, this is a control bypass.

Real Risk: MEDIUM. The fix is trivial (30 minutes). Risk scales with group membership.

Area: [src/app/api/telegram/webhook/route.ts](#)

Recommendation: Add TELEGRAM_ADMIN_IDS check to callback query handler. Reject non-admin with answerCallbackQuery('Unauthorized').

Architect Response: ACCEPTED. Remediation planned.

Architect Note: v2: Upgraded from LOW to MEDIUM per Architect's assessment (section 4.2 of response).

4.4 Low Findings

[Low] L-01: CORS Wildcard on Logging Endpoints [ACCEPTED]

Explanation: log-activity and log-event set Access-Control-Allow-Origin: *. Any origin can submit events.

Impact: Analytics data pollution from cross-origin requests.

Real Risk: LOW. Analytics-only, does not affect swap execution.

Area: [src/app/api/log-activity/route.ts](#), [src/app/api/log-event/route.ts](#)

Recommendation: Restrict CORS to teraswap.app and localhost.

Architect Response: ACCEPTED. Remediation planned.

[Low] L-02: localStorage Analytics Legacy Code [OUTDATED]

Explanation: analytics.ts stores trade events in localStorage. Originally flagged for quota risk.

Impact: LOW. Server-side /api/analytics is now the authoritative source. localStorage is legacy display-only.

Real Risk: VERY LOW. No longer the source of truth.

Area: [src/lib/analytics.ts](#)

Recommendation: Clean up legacy localStorage analytics or mark as deprecated.

Architect Response: OUTDATED. Remediation planned.

Architect Note: v2: Downgraded. Architect confirmed server-side analytics via /api/analytics is now authoritative.

[Low] L-03: Seed Data Runtime Guard Only [ACCEPTED]

Explanation: 350-trade demo dataset with NODE_ENV guard. Guard is simple and well-documented.

Impact: Misconfigured NODE_ENV could pollute production analytics.

Real Risk: VERY LOW.

Area: [src/lib/analytics.ts](#)

Recommendation: Move seed data to dev-only module excluded from production build.

Architect Response: ACCEPTED. Remediation planned.

5. Operational Review

5.1 Monitoring Architecture

- **H1 (Health Check):** Every tick probes teraswap.app and aggregator APIs (8s timeout). Feeds source state machine.
- **H2 (TLS/DNS Fingerprint):** Validates certificate issuer and DNS records against committed baseline. P0 on mismatch.
- **H5 (Quorum Consensus):** Every 5th tick. IQR-filtered, BigInt-safe. Correlated outliers trigger P0.
- **H6 (Telegram Bot):** /status, /quorum, /heartbeat, /disable, /lock (P0), /activate, /grace. Inline buttons.

The Cloudflare Worker operates **independently of Vercel** — if Vercel is compromised, the Worker continues triggering the monitoring endpoint and will detect the failure. The GitHub Actions watchdog was fixed on 22 April 2026 (commit ec2c2bc) to follow HTTP 307 redirects and uses WATCHDOG_ALERT_WEBHOOK for Telegram alerting.

5.2 Operational Runbooks

Architect Note: v2 addition: documenting existing runbooks per Architect's response.

- **docs/Runbooks/vercel-breach-rotation.md** — Battle-tested secret rotation runbook. Used during INC-2026-04-19-001 Vercel breach response.
- **docs/Runbooks/KV-troubleshooting.md** — Upstash Redis / KV diagnosis and repair procedures.
- **docs/Runbooks/worker-deployment.md** — Cloudflare Worker deployment, secret rotation, route migration.
- **docs/Runbooks/rate-limiter-verification.md** — End-to-end rate limiter verification after infra changes (prevents INC-2026-04-14-002 recurrence).

5.3 Alert Routing & Deduplication

Fan-out to Telegram, Email (Resend), Discord (webhook). KV dedup: standard 15-min/max 3, P0 5-min/unlimited. Oscillation detection on 3rd occurrence.

5.4 Fragility Points

- **Single KV dependency:** All monitoring, rate limiting, circuit breaker, alert dedup use one Upstash instance.
- **Vercel cold starts:** In-memory state lost. Warmup detection skips latency recording but circuit breakers reset.

- **No distributed transaction guarantees:** Mid-tick crash can leave partial state.
- **eth_getLogs replay risk:** Failures don't advance block cursor.

Architect Note: v2: The GitHub Actions watchdog 5-min resolution fragility has been partially mitigated by commit ec2c2bc (redirect handling + Telegram alert webhook).

5.5 Observability

Sentry at 10% trace sampling with intelligent noise filtering. Server-side security events to Supabase. Monitoring queryable via /api/monitor/status (public) and /heartbeat/admin (authenticated).

Gap: No structured logging framework (Pino/Winston). console.log is primary mechanism. Vercel Hobby provides minimal retention.

5.6 Test Coverage

Module Category	Test Files	Assessment
Auth & Security	auth, circuit-breaker, source-thresholds	Good: timing-safe, state transitions, P0 blocking
Calldata Validation	calldata-decoder, calldata-recipient	Good: selector groups, recipient extraction
Post-Execution	post-execution-validator	Good: Transfer parsing, shortfall classification
Monitoring	monitoring-loop, on-chain-monitor	Good: tick orchestration, event severity
Alerting	alert-wrapper, telegram	Good: fan-out, dedup, grace, callbacks
API Routes	kill-switch, heartbeat, status, tick, validate-execution, telegram/webhook	Good: auth, validation, error responses
Quorum	quorum-check	Good: IQR, BigInt, correlated detection
Frontend Components	NONE	CRITICAL GAP: 0 of 40+ components tested
Hooks	NONE	CRITICAL GAP: 0 of 16 hooks tested
Integration / E2E	NONE	GAP: no end-to-end swap flow tests

Total: 401 tests, all passing (as of commit 3339bef, 22 April 2026). Server-side coverage is strong; frontend coverage is absent.

6. Product Maturity Assessment

6.1 What Is Solid

- **Server-side security infrastructure:** Auth, rate limiting, calldata validation, quorum consensus, post-execution validation, and Chainlink pre-swap oracle are well-designed and well-tested.
- **Monitoring and incident response:** 4-component stack at zero cost. 5 documented incidents. Battle-tested rotation runbook. P0/non-P0 prefix-matching.
- **ADR-driven architecture:** 5 formal decision records with alternatives and cost analysis.
- **Security UX:** TransactionPreview (clear signing), Permit2EducationModal (anti-phishing), WalletSessionGuard (idle timeout), ActiveApprovals (revocation).
- **Smart contract design:** FeeCollector with ReentrancyGuard, router whitelist, 48h timelock, pause mechanism.
- **Post-breach hardening (April 2026):** GitHub App scoped to single repo (H-03), Deployment Protection (H-04), PATs deleted (H-09), branch protection, env vars marked Sensitive, watchdog fixed.

6.2 What Is Incomplete

- **Frontend testing:** Zero component and hook tests. The security UX layer is entirely untested.
- **Order engine:** Functional but beta. No keeper network integrated.
- **Multi-chain support:** Hardcoded to chainId 1. No abstraction layer.
- **User authentication:** Wallet-based only. No cross-device history.

6.3 What Is Fragile

- **KV single point of failure:** Upstash Redis is backbone for 5+ systems.
- **Vercel Hobby tier:** No SLA, 10s timeout (Deployment Protection now active).
- **In-memory state on serverless:** Circuit breakers, metrics, rate limiter reset on cold start.
- **Split routing:** Non-atomic with per-leg MEV exposure.

6.4 What Needs Hardening Before Scaling

- Upgrade to Vercel Pro for SLA, extended timeouts, team access, log retention.
- Add frontend integration tests for critical security paths.
- Implement KV fallback for rate limiting.

- Add minimumOutput to FeeCollector contract (on-chain output check).
- Convert systemic circuit breaker to alert-and-halt.
- Reduce on-chain scan cadence from 5-minute to 60-second.
- Implement structured logging (Pino/Winston) with external aggregation.

7. Priority Recommendations

Ordered by risk reduction per unit of effort. All findings accepted by the project Architect.

Priority	Action	Rationale	Effort
P0	Add minimumOutput to FeeCollector [H-04]	On-chain protection against compromised routers	1-2 days
P0	Convert circuit breaker to alert-and-halt [H-03]	Prevents user exposure during systemic collapse	0.5 day
P1	Add frontend integration tests [H-05]	Zero coverage on user-facing security UX	3-5 days
P1	Implement KV rate limiter fallback [H-01]	In-memory backup prevents full bypass	1 day
P1	Validate Telegram callback senders [M-05]	Prevents non-admin source control bypass	0.5 day
P1	Add split-swap MEV warning [H-02]	User must acknowledge non-atomicity risk	0.5 day
P2	Sync adapter CB with KV state [M-01]	Eliminates 90s cold-start vulnerability	1 day
P2	Reduce on-chain scan cadence [M-04]	Near-real-time critical event detection	0.5 day
P2	Fix grace period alert suppression [M-03]	Consistent [GRACE] across channels	0.5 day
P3	Restrict CORS on logging [L-01]	Prevents analytics pollution	0.5 day
P3	Separate Supabase roles [M-02]	Limits key compromise blast radius	1 day
P3	Structured logging	Replaces console.log; audit trails	2-3 days
P3	Move seed data to dev module [L-03]	Build-time exclusion vs runtime guard	0.5 day
P4	Upgrade Vercel to Pro	SLA, team access, extended timeouts	Operational

7.1 Architecture Decisions to Revisit

- **Split routing atomicity:** Evaluate a custom multicall router for atomic multi-leg execution.
- **In-memory vs persistent circuit breakers:** Consider single KV-backed breaker with local cache.
- **Fire-and-forget logging:** Consider synchronous logging for security events.
- **Multi-chain architecture:** Extract chain-specific constants into configuration module before adding chains.

- **Order engine keeper:** Define SLA requirements. Without fallback, orders may expire during downtime.

Appendix A: Remediation Plan

Planned sprint schedule for addressing all accepted findings. Provided by the project Architect on 23 April 2026.

Sprint	Scope	Findings Addressed	Effort	Status
9A	Quick-win security fixes	H-01, H-02, H-03, M-05	2 days	PLANNED
9B	FeeCollector minimumOutput	H-04	1-2 days	PLANNED
9C	Frontend integration tests	H-05	3-5 days	PLANNED
P2	Operational improvements	M-01, M-03, M-04	2-3 days	BACKLOG
P3	Low-priority cleanup	L-01, L-03, M-02	2-3 days	BACKLOG

Re-review commitment: Once Sprint 9A is complete, the Architect will provide commit hashes for each closed finding. A final re-review pass will update finding statuses in this document.

Appendix B: Corrections Applied in v2

This section documents all changes between v1 (22 April 2026) and v2 (23 April 2026), per the Architect's response.

#	Correction	Section(s) Affected
1	@vercel/kv replaced with @upstash/redis 1.37.0 throughout	2.1, 2.3, 3.4, H-01
2	Test count updated from ~323 to 401 (all passing)	Cover, 1.3, 5.6
3	Server-side analytics API (/api/analytics) now documented as authoritative	2.2, 3.4, 6.2, L-02
4	Post-breach hardening documented (H-03/H-04/H-05/H-09, branch protection)	1.4, 4.1, 6.1
5	Chainlink oracle registry expanded from 24 to 29 feeds	2.1, 2.3, 3.3 Layer 3
6	Chainlink pre-swap oracle added as Layer 3 in validation stack	1.2, 1.4, 2.4, 3.3
7	Cloudflare Worker independence from Vercel documented	2.2, 2.3, 5.1
8	Operational runbooks section added to section 5	5.2 (new)
9	GitHub Actions watchdog fix (ec2c2bc) documented	1.4, 5.1, 5.4
10	M-01 (frontend tests) upgraded from MEDIUM to HIGH -> H-05	4.2, 4.3, 7
11	L-03 (Telegram callbacks) upgraded from LOW to MEDIUM -> M-05	4.3, 4.4, 7
12	L-02 (localStorage) downgraded; server-side analytics is authoritative	4.4

#	Correction	Section(s) Affected
13	Remediation plan added as Appendix A	Appendix A (new)
14	Validation stack layers updated from 7 to 8	1.2, 3.3

— End of Report —